Assignment_06

Q1. Define network security and explain its fundamental principles and objectives. Discuss confidentiality, integrity, availability, authentication, and authorization.

Answer:

Definition of Network Security

Network security is the process of protecting computer networks, devices, and data from unauthorized access, misuse, modification, attacks, and destruction.

Its main objective is to ensure that network resources and information remain safe and available to authorized users.

Fundamental principles and objectives

1. Confidentiality

Ensures that information is accessible only to authorized users. Encryption helps maintain confidentiality.

Example: HTTPS encrypts information sent between a browser and a website.

2. Integrity

Ensures that data is not modified or deleted without authorization.

Example: A cryptographic hash can help detect changes in a downloaded file.

3. Availability

Ensures that network services and resources remain accessible when needed.

Example: Backups, redundant servers and DDoS protection help maintain availability.

4. Authentication

Verifies the identity of a user, device or server.

Example: Logging in using a password and an OTP.

5. Authorization

Determines which resources an authenticated user is allowed to access.

Example: A student can view marks, while an administrator can modify them.

Diagram

Network Security

Confidentiality

Integrity

Availability

Authentication

Authorization

Conclusion: Network security protects data, prevents unauthorized access and ensures reliable communication through these fundamental principles.

Q2. Explain the threat landscape in network security. Discuss different types of network attacks and vulnerabilities, along with suitable examples and preventive measures.

Answer:

Definition

The network security threat landscape refers to the different threats, attacks and vulnerabilities that can affect computer networks and information systems.

A threat is a potential cause of harm, while a vulnerability is a weakness that an attacker may exploit.

Types of network attacks

Attack	**Explanation and example**	**Prevention**
Malware	Malicious software such as viruses, worms and ransomware.	Antivirus, updates and backups.
Phishing	Fake emails or websites used to steal credentials.	User awareness, email filtering and MFA.
DoS/DDoS	Flooding a server with traffic to make it unavailable.	Traffic filtering, rate limiting and DDoS protection.
Man-in-the-Middle (MITM)	An attacker intercepts or alters communication.	HTTPS, TLS and trusted networks.
Password attack	Guessing or stealing passwords.	Strong passwords, MFA and login rate limits.
Spoofing	Falsifying an IP address, email or identity.	Authentication, filtering and secure protocols.
SQL injection	Malicious input manipulates database queries.	Parameterized queries and input validation.

Common network vulnerabilities

1. Weak passwords: Easy-to-guess passwords allow unauthorized access.
2. Outdated software: Unpatched systems may contain known security flaws.

3. Misconfiguration: Incorrect firewall rules or open ports may expose services.
4. Unencrypted communication: Attackers may read sensitive information transmitted without encryption.
5. Lack of access control: Users may receive more permissions than necessary.

Preventive measures

- Use firewalls and intrusion detection/prevention systems (IDS/IPS).
- Install security patches regularly.
- Use strong passwords and multi-factor authentication.
- Encrypt sensitive data using secure protocols such as TLS.
- Perform authorized vulnerability assessments and penetration testing.
- Maintain backups and monitor network logs.
- Apply the principle of least privilege.

Conclusion: Understanding network threats and vulnerabilities helps organizations select appropriate security controls and reduce the risk of cyberattacks.

Q3. Discuss the legal and ethical considerations in network security. Explain data privacy, responsible security testing, authorized access, and compliance with applicable cybersecurity laws.

Answer:

Network security professionals must protect systems while respecting privacy, legal requirements and the rights of other users.

1. Data privacy

Data privacy means protecting personal and sensitive information from unauthorized collection, use, disclosure or storage.

Example: A company should protect customers' passwords and personal information from unauthorized access.

2. Responsible security testing

Security testing identifies weaknesses in computer systems before attackers can exploit them.

Ethical security testing must be performed with proper permission and within a clearly defined scope.

Example: A penetration tester checks a company's website after receiving written authorization.

3. Authorized access

Users should access only the systems and information for which they have permission.

Accessing another person's account, bypassing security controls or modifying data without authorization may violate laws and organizational policies.

Example: A student should not attempt to access the university's confidential database without permission.

4. Compliance with cybersecurity laws

Organizations and security professionals must follow applicable laws, regulations and contractual obligations.

In India, important legal frameworks include:

- Information Technology Act, 2000: Addresses various legal aspects of electronic records and specified cyber offences.
- Digital Personal Data Protection Act, 2023: Establishes a framework for processing digital personal data, subject to its provisions and applicable commencement notifications and rules.
- CERT-In Directions: Certain entities must comply with applicable cybersecurity incident-reporting and related requirements.

Legal requirements depend on the activity, organization, jurisdiction and applicable rules.

5. Ethical responsibilities

- Maintain confidentiality of sensitive information.
- Obtain permission before testing a system.
- Avoid unnecessary access to personal data.
- Report discovered vulnerabilities responsibly.
- Do not misuse security tools or disclose confidential information.
- Follow professional codes of conduct.

Conclusion: Legal compliance and ethical behaviour build trust, protect personal information and ensure that security testing is conducted responsibly.

Q4. Explain the role of cryptography in securing network communications. Describe the working and security features of SSL/TLS and IPsec protocols.

Answer:

Role of cryptography in network security

Cryptography uses mathematical techniques to protect information from unauthorized access and modification.

Its major functions include:

1. Encryption: Protects confidentiality by converting plaintext into ciphertext.
2. Hashing: Helps detect changes in data.
3. Digital signatures: Support authentication, integrity and evidence of the signer's approval.
4. Message authentication: Verifies message integrity and authenticity using mechanisms such as HMAC.

A. SSL/TLS

SSL stands for Secure Sockets Layer, while TLS stands for Transport Layer Security. TLS is the modern protocol; SSL is obsolete and should not be used.

TLS protects communication between applications, such as a web browser and an HTTPS website.

Working of TLS

Client (Browser)

TLS Handshake

Negotiates security parameters, authenticates the server and establishes session keys.

Secure Encrypted Communication

Client and server exchange protected application data.

Security features of TLS

- Encrypts data transmitted between the client and server.
- Uses digital certificates to authenticate the server.
- Protects message integrity using cryptographic authentication.
- Uses session keys for efficient protection of application data.

Example: Online banking websites use HTTPS, which runs over TLS.

B. IPsec

IPsec stands for Internet Protocol Security. It is a suite of protocols that protects IP communication at the network layer.

It is commonly used in virtual private networks (VPNs).

Working of IPsec

1. The communicating systems negotiate security parameters, often using IKE/IKEv2.
2. They establish security associations and cryptographic keys.
3. IP packets are protected using IPsec mechanisms.

4. The receiving system verifies and processes the protected packets.

Main IPsec protocols

- AH (Authentication Header): Provides integrity and origin authentication, but not encryption.
- ESP (Encapsulating Security Payload): Can provide encryption, integrity and authentication.

IPsec modes

- Transport mode: Protects the IP packet's payload while retaining the original IP header.
- Tunnel mode: Protects the entire original IP packet by encapsulating it inside a new IP packet.

TLS vs IPsec

Feature	**TLS**	**IPsec**
Layer	Between application protocols and transport	Network layer
Common use	HTTPS and secure application connections	VPNs and IP network protection
Protection scope	Particular application connection	IP traffic according to policy
Common mechanisms	TLS handshake and record protection	ESP/AH and security associations

Conclusion: TLS protects application communication, while IPsec protects IP traffic at the network layer. Both use cryptographic techniques to improve network security.

Q5. What is Public Key Infrastructure (PKI)? Explain its components and working. Discuss the role of digital certificates and Certificate Authorities in establishing trust and securing network communications.

Answer:

Definition

Public Key Infrastructure (PKI) is a system of hardware, software, policies, procedures and trusted entities used to manage public keys and digital certificates.

PKI helps establish trust between users, devices and servers in a network.

Components of PKI

1. Certificate Authority (CA)

A trusted organization or entity that issues and digitally signs certificates after following appropriate validation procedures.

2. Registration Authority (RA)

An entity that may verify the identity of certificate applicants on behalf of a CA.

3. Digital certificate

An electronic document that binds an identity to a public key and is digitally signed by a CA or another issuer.

4. Public and private keys

The public key may be shared, while the corresponding private key must remain secret and protected.

5. Certificate repository

A location where certificates and related information can be published or retrieved.

6. Certificate revocation and status checking

Mechanisms such as Certificate Revocation Lists (CRLs) and Online Certificate Status Protocol (OCSP) help determine whether a certificate has been revoked.

Working of PKI

1. Applicant generates a key pair

Public key + private key

2. Identity validation

CA or RA checks the applicant according to its procedures.

3. CA issues a digital certificate

The certificate binds the verified identity to a public key.

4. Receiver validates the certificate

Checks issuer signature, validity period, hostname, trust chain and revocation status as appropriate.

5. Secure communication

TLS uses authenticated key establishment to create secure session keys.

Role of digital certificates

Digital certificates:

- Bind a subject's identity to a public key.
- Help authenticate websites and servers.

- Support digital signatures and secure key establishment.
- Allow clients to verify the certificate chain against trusted CA certificates.

Role of Certificate Authorities

A CA issues and digitally signs certificates. A receiver checks that signature and verifies the certificate chain against its configured trust anchors.

For example, when a user visits an HTTPS website, the browser validates the server certificate before relying on it for server authentication.

A valid certificate alone does not guarantee that a website is honest or free from malware; it establishes specific identity and key-binding assurances under the certificate's validation rules.

Conclusion: PKI provides a framework for digital trust by managing keys, issuing certificates and enabling certificate validation in secure network communication.